ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Inductive Automation Ignition 8.1 & 8.3 - SCADA/HMI software platform · Component type: **Software Application (SAR) - SCADA/HMI platform** · Target SL = SL 3

Where to work	**Gateway web UI** http://host:**8088** (→ HTTPS **8043** when Force SSL); **Designer** (launched from the Gateway); **Gateway Network** TCP **8060**; **OPC UA 62541**. Config files: `ignition.conf`, `gateway.xml`. Logs: Status › Diagnostics › Logs, `wrapper.log`.
8.1 vs 8.3	**8.1:** security under **Config › Security**. **8.3:** redesigned nav - **Platform › Security › General Settings**; adds **Roles & Permissions**, **Secrets Management**, OPC UA **Roles/Permissions**, Deployment Modes; RPC uses **Protobuf** (no Java serialization). (!) Permissions do **not** auto-migrate 8.1→8.3 - re-verify.
How to read	Each row = one SL-3 requirement, individually. Default read-only: review settings + capture screenshots/exports. Mark **Pass / Fail / Partial / N/A / Deferred**; where Ignition can't meet a control natively (e.g., lockout), record **Partial** + compensating control + residual risk. Wireless (1.6) and embedded-device reqs are **N/A** for a software application.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the full **Gateway Backup (.gwbk)** (Config › System › Backup/Restore), **tag exports** (Designer › Tag Browser › Export, per tag provider), **named-query / DB-connection** configs, a **running-threads dump** (Status › Diagnostics › Threads), **project exports**, and the **wrapper / gateway / audit logs**.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 1.1	Human user identification & authentication	Confirm **every** access path authenticates before access: Gateway web (Home / Status / Config), Designer, Perspective & Vision clients, OPC UA server, DB. **8.1:** Config › Security › General - a real **System Identity Provider** is set; **Gateway Config / Status / Home Permissions** are **not empty** (empty = Public = unrestricted); Designer Authentication Strategy = IdP (or Classic w/ roles). **Test:** browse `/web/config` and `/web/status` logged-out → must redirect to IdP login. **Ext. tools:** Burp/ZAP (authn, isolated); `curl -I https://gw/web/config` (unauth → expect redirect); ReadOnlyEnum.	All interfaces require login; no permission field left blank; no anonymous path to config/status. Screenshot each redirect.	8.3: settings under **Platform › Security › General Settings** + new **Roles & Permissions**. Permissions do **not** auto-migrate 8.1→8.3 - re-verify after upgrade.
SR/CR 1.2	Software process & device I&A	OPC UA server, Gateway Network (GAN) peers, and DB connections must authenticate. Config › OPC UA › Server Settings: **disable Anonymous**, require Username/Password or Certificate. GAN › require SSL + manual connection approval (two-way cert). **Test:** connect an unprovisioned OPC UA client / GAN peer → rejected. **Ext. tools:** UaExpert (OPC UA anonymous/cert); `nmap -p 62541,8060 gw`; Wireshark.	OPC UA anonymous OFF; GAN incoming requires SSL + approval; no rogue peer connects.	8.3: OPC UA **Authentication** = Anonymous/Username/**Certificate**; new **OPC UA Server Permissions** tab + OPC UA Roles; Secure Connection Mode.
SR/CR 1.3	Account management	Review user source / IdP accounts: named users, disable/remove defaults & sample accounts, least-privilege roles. Config › Security › Users, Roles (Classic) or the IdP + User Grants. **Ext. tools:** Gateway/Designer review; ReadOnlyEnum (account/service enumeration).	Named accounts only; no shared logins; admin membership minimal & justified.	8.3: **User Grants** & attribute mapping per-IdP; Administrator auto-listed under Authenticated/Roles.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5	Authenticator management	Manage authenticators across the platform (Config › Security › Users/Roles or the IdP): confirm the **default admin credential is changed**; OPC UA / GAN / DB service credentials are managed and rotated; no sample/default accounts remain; reset/rotation procedure exists. **Ext. tools:** Gateway/Designer review; `grep -ri password *.xml` on config exports (no plaintext); ReadOnlyEnum.	Defaults changed; service credentials managed/rotated; no plaintext secrets (8.3 Secrets Management).	8.3: **Secrets Management** (File/Remote providers) keeps credentials/keys out of config. 8.1: config credentials are obfuscated, not vault-grade - compensating control.
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Internal user source: Config › Security › Users/Roles › (source) › **Password Policy** - set minimum length, complexity, expiration and history to IEEE 1686 / NERC CIP-007 intent. If AD/IdP, policy is enforced upstream (capture evidence). **Test:** attempt to set a weak password → rejected. **Ext. tools:** Policy review; Hydra/Medusa (isolated, authorized) to confirm complexity/rejection.	Enforced min length + complexity, expiry & history; weak passwords rejected; no default passwords remain.	8.3 adds **Prohibit Password**, **Prohibit Username**, **Max Consecutive Repeated Characters** to Internal Authentication.
SR/CR 1.8	PKI certificates	Gateway TLS cert (Config › Networking / Web Server + Security Certificates) is **CA-signed**, not the self-signed default; OPC UA application cert; IdP (SAML/OIDC) signing certs present & valid. Confirm chain and expiry. **Ext. tools:** testssl.sh; `openssl s_client -connect gw:8043 | openssl x509 -noout -issuer -dates` (confirm not self-signed).	CA-signed Gateway cert installed; self-signed default replaced; certs valid & not expired.	Same mechanism both versions.
SR/CR 1.9	Strength of public key-based authentication	Confirm strong keys/algorithms on those certs and TLS: RSA >=2048 or ECC; OPC UA Basic256Sha256; weak/legacy key sizes and ciphers disabled. **Ext. tools:** testssl.sh / sslscan (key size + cipher grade); openssl.	Strong key sizes/algorithms; weak keys/ciphers disabled.	Same mechanism both versions.
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts (lockout)	**Known gap:** the Ignition Internal user source has **no native account lockout**. Verify lockout is provided by the IdP (AD / Okta / Duo / ADFS) or an upstream reverse-proxy / WAF. **Ext. tools:** Hydra/Medusa (isolated, authorized) - repeated logins to confirm lockout or prove the gap.	Lockout enforced via IdP or proxy. If internal-only: record as **Partial** + compensating control (IdP/WAF) + residual risk.	Both versions - plan a federated IdP for SL-3.
SR/CR 1.12	System use / logon banner	Perspective & Vision login screens can show a use-notification message (project login props). The Gateway config login has no native banner - use a reverse-proxy banner as a compensating control. **Ext. tools:** Browser / curl (confirm banner on client + config login).	Banner shown on client login; config-login banner via proxy (Partial if absent).	Both versions.
SR 1.13	Access via untrusted networks (MFA)	Require **MFA** for remote/untrusted access via the IdP (Duo/Okta/SAML) and enforce TLS (Force SSL). Restrict via Security Zones + VPN. (System-level SR - no base CR 1.13.) **Ext. tools:** Browser via IdP (MFA prompt); testssl.sh (force-SSL redirect).	MFA required for untrusted-network access; HTTP disabled; VPN/segmentation in place.	Both versions (IdP-driven).

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 2.1	Authorization enforcement	RBAC via **Security Levels** + **Security Level Rules** (expressions on roles / zones / IdP attributes) applied to Gateway Config/Status/Home, Service Security, and project/view/component permissions. **Test:** log in as a low-privilege user → cannot reach Config, cannot write restricted tags. **Ext. tools:** Low-privilege account negative test; Burp/ZAP (authz, isolated).	Least privilege enforced on every interface; negative test confirms denial.	8.3: new **Roles & Permissions** (Platform › Security › General Settings) + **OPC UA Server Permissions** / OPC UA Roles.
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use Control for Portable and Mobile Devices	Assess per objective: Enforce configurable usage restrictions for portable/mobile devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/SAR 2.4	Mobile code	Control client-side/mobile code: restrict Perspective/Vision scripting to trusted project resources; only **signed modules**; sandbox the embedded browser. Review named-query/script exposure. (2.4 is a system SR + a SAR component requirement - there is no base CR 2.4.) **Ext. tools:** Burp/ZAP (isolated); module signature review.	Only signed modules; scripting restricted; unsigned/3rd-party code controlled.	8.3: JxBrowser `ignition.jxBrowser.sandboxMode`; module **quarantine** actions.
SR/CR 2.5	Session lock / inactivity timeout	Set idle timeouts: Perspective *Session Inactivity Timeout*; Vision client timeout; Gateway **User Inactivity Timeout** (Config › Security › General, 8.1.1+); Designer **Auth Token Inactivity Timeout** (8.1.24+, default 10 min). **Ext. tools:** Manual idle-timeout test on each client + Gateway web.	Timeouts configured (non-zero) on client, gateway web, and designer.	Both versions; Designer token TTL also configurable.
SR/CR 2.6	Remote session termination	Status › Perspective Sessions / Vision Clients - confirm active sessions are **visible** and can be **terminated** on demand; a terminated session is forced to re-authenticate. **Test:** terminate a live test session → it must re-auth to continue. **Ext. tools:** Gateway Status › Perspective Sessions / Vision Clients (view/terminate).	Sessions visible & terminable on demand; terminated session must re-auth.	Both versions.
SR/CR 2.7	Concurrent session control	Bound concurrent sessions. Native limits are limited - document the max concurrent per user and enforce via the IdP / reverse proxy / license where required. **Ext. tools:** Open parallel sessions to observe behavior; IdP/proxy policy review.	Concurrency bounded/dispositioned; compensating control recorded where native limit absent (Partial).	Both versions; concurrency largely compensating (IdP/proxy/license).
SR/CR 2.8	Auditable events	Assign a **Gateway Audit Profile** (Config › Security › General › Gateway Audit Profile) logging to a DB audit table; enable auditing on tag writes, auth, and config changes. **Test:** make a change → confirm a row with user, action, timestamp. **Ext. tools:** SQL client: query `audit_events` (8.3) / `AUDIT_EVENTS` (8.1).	Audit profile active; security-relevant events (login, config change, tag write) captured with user + time.	8.3: **route-actor MDC** keys enrich Gateway logs w/ user / token / client IP.
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	Gateway time source / NTP correct; audit & historian timestamps consistent (tz). Verify server clock & NTP. **Ext. tools:** NTP check; Wireshark (NTP).	Accurate synced time; audit timestamps match.	Both versions.
SR/CR 2.12	Non-repudiation	The audit profile records the **username** on each change (config, tag write, ack). Confirm per-user attribution end-to-end. **Ext. tools:** SQL client on the audit table (username per action).	Every change attributable to a named user in the audit log.	Both versions.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 3.1	Communication integrity (TLS)	Enforce TLS on all channels: **Force SSL** (Config › Networking / Web Server) so 8088→8043; Perspective over HTTPS; OPC UA signing (Basic256Sha256); GAN SSL; DB SSL. **Test:** confirm HTTP redirects, cert valid; Wireshark capture shows TLS. **Ext. tools:** testssl.sh / sslscan; `nmap --script ssl-enum-ciphers -p 8043 gw`; Wireshark (confirm TLS).	HTTP disabled/redirected; TLS on web, OPC UA, GAN, DB; valid certs.	Both versions; 8.3 RPC uses Protobuf (not Java serialization).
SR/SAR 3.2	Protection from malicious code	Only manufacturer-**signed modules** load. Verify `ignition.conf` does **not** set `-Dignition.allowunsignedmodules=true`. OS AV with Ignition-aware exclusions; restrict module install to admins. (3.2 is a system SR + a SAR component requirement - there is no base CR 3.2.) **Ext. tools:** Inspect `ignition.conf`; module list; host AV; Nessus/OpenVAS (CVEs, isolated).	Unsigned modules disallowed; module list all signed; install restricted.	8.3: unsigned/incompatible modules are **quarantined** with resolve/delete actions.
SR/CR 3.3	Security functionality verification	Re-verify security settings after any change using this checklist / the IA Hardening Guide; compare against a known-good Gateway backup (.gwbk). **Ext. tools:** .gwbk diff vs baseline; IA Hardening Guide checklist.	Documented re-verification; settings match the hardening baseline.	Both versions.
SR/CR 3.4	Software & information integrity	Signed modules (above); protect & integrity-check Gateway backups (.gwbk); secrets not stored in plaintext config; project-resource integrity. **Ext. tools:** `sha256sum gw.gwbk`; verify module signatures.	Signed modules; verified backups; secrets protected.	8.3: **Secrets Management** encrypts credentials/keys out of config; Protobuf persistence.
SR/CR 3.5	Input validation	Verify Perspective/Vision inputs are validated and DB access uses **parameterized Named Queries** (no string-built SQL → SQL injection). Review scripting for unsafe input handling. (3.5 is SR + base CR - there is no SAR 3.5.) **Ext. tools:** sqlmap (isolated) + manual Named-Query review; Burp/ZAP.	Parameterized queries; component input validation; no injectable paths.	8.3 Form component adds validation; both versions support Named Queries.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.8	Session integrity	TLS-protected sessions; secure session cookies; bounded auth-token TTL (Designer Auth Token Time-To-Live); Perspective session security. **Ext. tools:** Burp/ZAP (session cookie/token); Wireshark.	Sessions bound to TLS + token TTL; no fixation/replay.	Both versions.
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 4.1	Information confidentiality	Confidential data protected in transit (TLS everywhere, per 3.1) and at rest (DB encryption; **Secrets Management** for credentials in 8.3). Note: the Gateway backup (.gwbk) contains secrets - protect it. **Ext. tools:** testssl.sh; Wireshark (no cleartext creds/tags); secrets review.	TLS in transit; credentials/secrets encrypted at rest; .gwbk handled as sensitive.	8.3: Secrets Management (File/Remote providers). 8.1: credentials in config are obfuscated, not vault-grade - compensating control.
SR/CR 4.2	Information persistence	On decommission/re-use, purge secrets, projects, historian, and backups. Verify no plaintext credentials persist in config exports. **Ext. tools:** grep config exports for plaintext secrets; review purge steps.	Documented purge; no residual secrets in exports/backups.	8.3 Secrets Management centralizes removal.
SR/CR 4.3	Use of cryptography	TLS 1.2/1.3 with strong cipher suites; CA-signed certs (>=2048 RSA/ECC); OPC UA Basic256Sha256. Review web-server TLS config. **Ext. tools:** testssl.sh / sslyze; `nmap --script ssl-enum-ciphers` (protocol + cipher grade).	Modern TLS + strong ciphers; weak protocols disabled.	Both versions.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 5.1	Network segmentation	Define **Security Zones** (Config › Security › Security Zones) by IP/host/GAN identity and apply them in Service Security & Security Level Rules. The Gateway host lives in a segmented OT/DMZ zone behind a firewall. **Ext. tools:** Nmap from each zone; PortQry (reachability by segment).	Security zones defined & used; Gateway in a controlled segment; firewalled.	Both versions.
SR 5.2	Zone boundary protection	Restrict/inspect boundary flows: firewall only required ports (8088/8043 web, 8060 GAN, 62541 OPC UA); front Perspective with a reverse proxy/WAF; GAN limited & one-directional where possible. (System-level SR - no base CR 5.2.) **Ext. tools:** `nmap -p 8088,8043,8060,62541 gw` (only required open); firewall-rule review.	Only required ports open; reverse proxy/WAF at the boundary; GAN scoped.	Both versions; 8.3 GAN has its own thread-pool settings.
SR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR 5.4	Application Partitioning	Assess per objective: Support partitioning of data, applications, services by criticality.	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 6.1	Audit log accessibility	The audit profile logs to a queryable DB table; Gateway logs at Status › Diagnostics › Logs; confirm authorized staff can read/export audit records. **Ext. tools:** SQL client on the audit table; log export test.	Audit records queryable & exportable by authorized users only.	Both versions.
SR/CR 6.2	Continuous monitoring	Forward Gateway logs to **SIEM/syslog** (logback/wrapper config or a log forwarder); monitor health tags, gateway diagnostics, and alarms. Confirm alerting on security events. **Ext. tools:** Syslog listener (`nc -lu 514`) to confirm forwarding; Nozomi/Frenos (passive).	Logs shipped to SIEM; monitoring/alerting active for security events.	8.3: MDC keys (user/token/client IP) improve log correlation.

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR/CR 7.1	Denial of service protection	Bound resource use so the Gateway stays available under load: query timeouts, connection/session limits at the reverse proxy, gateway thread limits (`gateway.maxThreads`; 8.3 dedicated **GAN thread pool** settings), and **redundancy** to absorb load. Rate-limit at the boundary proxy. **Ext. tools:** (Isolated) load/soak test; review resource limits/timeouts.	Resource limits/timeouts set; boundary rate-limiting; redundancy available for load.	8.3 adds a dedicated GAN thread pool & new settings.
SR/CR 7.2	Resource management	Monitor and bound consumption: Status › Diagnostics › Performance (Gateway memory/CPU/threads), tag/scan-class load, and DB connection-pool sizing; alarm on resource thresholds so exhaustion is caught early. **Ext. tools:** Gateway Status › Diagnostics › Performance; review pool/thread settings.	Resources monitored & bounded; alerting on thresholds; no exhaustion-based loss of function.	Both versions; 8.3 GAN pool sizing helps.
SR/CR 7.3	Control system backup	Take a verified **Gateway Backup** (Config › System › Backup/Restore → .gwbk); schedule backups (EAM); store off-box; hash it. The .gwbk contains secrets - handle as sensitive. **Ext. tools:** `sha256sum gw.gwbk`; confirm backup schedule (EAM).	Recent verified .gwbk; scheduled & stored off-box; hash recorded.	8.3: redundancy backup-version overrides; EAM leased licensing.
SR/CR 7.4	Control system recovery & reconstitution	**Test a restore** of the .gwbk on a spare/lab Gateway; confirm redundancy failover; agree RTO/RPO with ops; document the reconstitution procedure. **Ext. tools:** Restore on a lab Gateway (recovery test); redundancy failover test (isolated).	Restore tested on a lab Gateway; failover confirmed; RTO/RPO met & documented.	8.3: redundancy backup-version config overrides.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	8.1 vs 8.3 notes
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Document and verify all security-relevant settings (this checklist) and capture them in the .gwbk; changes go through change control. **Ext. tools:** .gwbk capture/compare; IA Hardening baseline.	Settings documented & captured in the backup; change-controlled.	Both versions.
SR/CR 7.7	Least functionality	Disable unused modules (Config › Modules), protocols, OPC Quick Client, sample/quickstart projects, and demo data; disable plain HTTP; remove default accounts. **Ext. tools:** Nmap (open ports/services); module-list review.	Only required modules/protocols enabled; HTTP off; demo content removed.	8.3: Quick Start / sample content & module management updated.
SR/CR 7.8	Component inventory	Record installed modules & versions (Config › Modules; Home › Gateway version), edition, drivers, and third-party modules for the inventory. **Ext. tools:** Module/version list; ReadOnlyEnum; Nozomi/Frenos (inventory).	Complete module/version inventory captured.	8.3: EAM ModuleVersions system tags aid inventory.

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Ignition Gateway & Designer (read-only)	Native settings, audit, modules, project security	Log in with a least-privilege account; review Config/Status on the Gateway and open projects read-only in the Designer. Compare against the IA Hardening baseline.	Read-only account; no changes on production.
Gateway Backup (.gwbk)	Baseline, drift, recovery (3.3, 3.4, 7.3, 7.6)	Config › System › Backup/Restore → export .gwbk. Hash it: `sha256sum gw.gwbk`; compare across reviews for drift. Restore on a lab Gateway to test recovery.	Contains secrets - protect at rest/in transit.
Audit log (audit_events table)	Auditable events, non-repudiation (2.8, 2.12, 6.1)	SQL client: `SELECT * FROM audit_events ORDER BY timestamp DESC` (8.3) / `AUDIT_EVENTS` (8.1). Trigger a change and confirm a row with user + action + timestamp.	Read-only DB query.
testssl.sh / sslscan / sslyze	TLS, cipher & cert strength (1.8, 3.1, 4.1, 4.3)	`testssl.sh https://gw:8043` or `sslscan gw:8043`. Confirm TLS 1.2/1.3 only, weak ciphers disabled, valid cert, force-secure redirect.	Scans Gateway web port; read-only/safe.
openssl	Certificate inspection (1.8, 1.9)	`openssl s_client -connect gw:8043 | openssl x509 -noout -subject -issuer -dates`. Confirm CA-signed (not self-signed default), key size, and expiry.	Read-only.
Nmap / PortQry / TCPing	Port/service exposure, segmentation, TLS enum (1.2, 5.1, 5.2, 7.7)	`nmap -sT -p 8088,8043,8060,62541,1883,8883 -T2 gw`; `nmap --script ssl-enum-ciphers -p 8043 gw`. Scan from each zone to prove segmentation.	Tune timing (-T2 or slower) on production.
OPC UA client (UaExpert / open62541)	OPC UA server auth & policies (1.2, 3.1)	Connect `opc.tcp://gw:62541`. Try Anonymous (expect denied if disabled), then Username & Certificate; verify Basic256Sha256. 8.3: confirm OPC UA Roles/Permissions.	Read-only browse; do not write live tags.
Wireshark / tcpdump	Comm integrity, confidentiality, monitoring (3.1, 4.1, 6.2)	SPAN/tap capture on the Gateway segment; confirm traffic is TLS (no cleartext credentials or tag values); inspect NTP and session handshakes.	Passive; SPAN/tap only - no inline.
Web app proxy (Burp / OWASP ZAP)	Authn/authz, session, input, 8.3 REST (1.1, 2.1, 3.5, 3.8)	Proxy an authenticated session; run authorization tests (low-priv user cannot reach admin routes), check security headers, cookies, and REST/OpenAPI endpoints.	ISOLATED/representative env only; written authorization.
sqlmap	SQL injection via inputs / named queries (3.5)	Target a form/endpoint that reaches a query: `sqlmap -u "https://gw/..." --cookie=... --batch`. On production, prefer manual Named-Query parameterization review.	ISOLATED only; authorization required.
Hydra / Medusa	Lockout & password behavior (1.11, 1.7)	Authorized repeated logins to confirm lockout triggers - or to demonstrate the internal source has no native lockout (records the gap + compensating control).	ISOLATED/authorized only; never on production.

Tool / method	Verifies	How to use — steps / example	Constraints
ReadOnlyEnum	Host/network/protocol/config enumeration (1.3, 7.7, 7.8)	Run against the host supporting the Gateway to enumerate services, ports, and configuration read-only.	Needs host read access; read-only.
SCAP: SCC / OpenSCAP / CIS-CAT / STIG Viewer	Host OS + Java baseline (3.3, 7.6)	Benchmark the Windows/Linux host and JRE the Gateway runs on; review results in STIG Viewer.	Host-level; org-approved baseline.
Nessus / OpenVAS	Known-CVE vulnerability scan (3.2, general)	Authenticated scan of the Gateway host, Java, and modules; cross-check IA Trust Center advisories.	ISOLATED/representative; authorization.
IA Security Hardening Guide + Trust Center	Configuration baseline & advisories (all)	Use as the STIG/CIS-equivalent baseline for Ignition; verify settings against it; subscribe to the Trust Center for advisories.	security.inductiveautomation.com.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.